UNTAP · AGENTS AT WORK

ThreatLens

Threat modeling for SMEs in minutes

AHMED ALAA ELDIN

Principal Application Security Consultant

GITHUB.COM/AHMEDANDALOES/THREATLENS

Who we built for

Clinics

Patient records and online booking. Health data (PHI) on the line.

E-commerce

Stores taking payments through Paymob and Fawry callbacks.

HR portals

Payroll, salaries and national IDs or Iqamas for Saudi staff.

A threat model costs a week most SMEs never buy.

3–5 consultant days. 1–3 weeks to schedule. Stale at the next release.

The workflow replaced

MANUAL ENGAGEMENT STEP	THREATLENS TOOL
Kick-off workshop and architecture intake	parse_architecture
Draw the DFD and trust boundaries	enumerate_components · render_diagram
STRIDE session per component and flow	stride · flows · API · system analysis
Map to OWASP · ASVS · CWE and rate risk	map_to_owasp · score_risk
Peer review for gaps	reflect (loops back to repair)
Write the remediation roadmap and report	build_remediation_plan · render_report

How the agent works

PLAN

An LLM via function calling or an offline policy picks the next tool.

ACT

12 tools share one state backed by 42 STRIDE rules and 35 mitigations.

REFLECT

A coverage self-check loops back and a guardrail completes any skipped step.

RUN ANYWHERE

Offline with no API key or any OpenAI-compatible LLM including Ollama Cloud.

Demo: clinic booking

43

Findings across 11 components

4/25

Critical / High (+14 Medium)

9/10

OWASP Top 10 2021 categories

6/6

STRIDE categories

Measured impact

97%

Recall: 37 of 38 checklist threats

83%+

Less expert time: 83–95% (estimate)

≤$450

Per model vs $1,500–4,500 (estimate)

Results across four SMEs

EXAMPLE	INPUT	AGENT TIME	FINDINGS	C / H / M	OWASP	FIX PLAN
Shifa Care clinic	YAML	12.9 ms	43	4 / 25 / 14	9/10	54 dev-days
Nile Threads store	YAML + OpenAPI	17.9 ms	43	10 / 22 / 11	10/10	43 dev-days
Masar HR portal	JSON	3.8 ms	25	1 / 15 / 9	8/10	34.5 dev-days
Dawaa pharmacy	Free text	n/a	33	4 / 18 / 11	8/10	49.5 dev-days

Roadmap

Shipped

v1.0 offline agent with LLM mode and Streamlit UI. 12 offline tests

Next

Requirement-level ASVS IDs and an independently reviewed benchmark

Then

Run in CI on every architecture change with diffs between releases

Later

Arabic reports and PDPL · NCA ECC evidence packs for auditors

Run it offline today

github.com/ahmedandaloes/threatlens — run offline in 3 commands. No API key needed.

1

pip install -r requirements.txt

2

python -m threatlens examples/clinic_booking.yaml

3

Open the HTML report